

Lecture 2 - Background

Summary: Mostly went through definitions.

Definition list:

- Safety: Being in a state with absence of harm.
- Security: How resistant you are to harm.
- Reliability: “Ability of a system or component to function under state conditions for a specified period of time (IEEE)”
 - Mean Time to Failure: Average time until first failure
 - Mean Time Between Failure: Average time until next failure, usually shorter than MTF. See diagram.

```
diagram: o = start, x = failure
o-----x-----x-----x-x->
^-----MTF-----^      ^-MBTF-^
```

- Risk management: Classifying threats and vulnerabilities and estimating their impact.
- Information Security: you know what CIAvail/CIAuth is + non-repudation.
 - Identification: Claiming to be someone
 - Authentication: Verifying you are someone
 - Authorization: Having the right to perform a certain action.
- Dependability: Some combination of Confidentiality, Integrity, Availability, Safety, Reliability, Maintainability.
- Verification: Does the software follow the specification / requirements?
- Validation: Does the software fulfill needs of stakeholders? Requirements complete and relevant?
- Safety Analysis:
 - GSN: Top-down approach that graphically reason about model. Starts with goal and divides until sub-goals with solutions.
 - Fault Tree Analysis: Top-down approach using boolean logic to reason about systems.
 - Event Tree Analysis: Bottom-up approach that starts with some malfunction and works until end state.
- Dynamic Analysis: Analyzing at runtime. Usually efficient but can lack coverage (esp. concurrency related).
- Static Analysis: Analyzing at compile time i.e analyzing written code/model/text (=statically). Covers all possible behaviours. Can lead to false warnings.

Examples

Examples that Cyrille covered in the lecture. Disclaimer that you could that of course these examples are non-exhaustive.

For the Safety, Security, Reliability triangle example in the lectures, Cyrille argued that a car that is (visibly and) severely broken would be safe and secure, but not reliable, since you wouldn't attempt to enter a car that's broken in the first place, meaning it can do you no harm.

For examples on how to protect oneself against attack and vulnerabilities, we mentioned system modelling, having backups, logging and active monitoring, obfuscation.

For the OWASP slides, Cyrille expresses his sadness/disappointment (?) that some of the top 10 security problems have been solved with technology yet still remain in the top 10.

Example of verification: Testing.

Examples of verification verdicts: Halting problem prevents writing algorithm in general case

- TP: Correct software yay.
- FP: Happens sometimes with system modelling

- FN: Uh oh.
- TN: Correct software yay.

Example of Event Tree Analysis:

- If a fire breaks out, if you extinguish immediately then you have minimal damage
- If you don't extinguish, but remember to close the door, then you have moderate damage.
- If you don't do anything, you have severe damage.

Explanation of Strengths and Weakness Triangles: The triangles are supposed to represent time (y-axis) and amount of states (x-axis), going up to down. Dynamic analysis means only testing one state and static analysis means testing set of behaviours that cover all cases but can also cover too many cases (represented with the overdimensioned boxes).

Example of abstract interpretation: The question mark is supposed to be {+, -}.

Other

We didn't actually talk about package management. Nor HAZOP. Nor Hazard argumentation. Nor V-model nor run-time verification. Not really model-based testing.

Cyrille went into a tangent where his team discovered a bug in Java ArrayList related to error throwing (which was implementation dependent at the time). Fixed in Java 11.

And doors are very robust. Remember to close the door when you are evacuating from a fire because, closed doors prevent fire spreading (yes Cyrille talked about this).